

List of features to check with the copilot.

control_00001

Hostname:

Explanation:

The has some specific characteristics that should be taken into consideration:

Name parts are separated by an underscore. These are the parts of a valid device name.

1. Company name.
2. Country
3. Type: router, switch, wlc, access-point, pbx. firewall,etc.
4. Function: mpls, internet, DSL,
5. Site
6. Device number

Name example:

INTEL_CR_RT_INT_BLN_01

Field	Value
Company name	INTEL
Country	CR
Type	RT (Router)
Function	INT (Internet)
Site	BLN
Device number	01

Command:

hostname <hostname>

Variables:

<hostname>

<company_name>

<country>

<type>

<function>

<site>

<device_number>

Not compliance condition:

1. Name does not meet name convention
2. Host name is generic like router, switch, wireless_controller, access_point

Exceptions

No specific exceptions identified for this control.

Severity

Low

Risk

An inconsistent or generic hostname hinders asset identification, audit logging, and security incident response.

Remediation Recommendation

Configure the hostname following the corporate naming convention: *hostname* *<COMPANY>_<COUNTRY>_<TYPE>_<FUNCTION>_<SITE>_<DEVICE_NUMBER>*.

Evidence

The 'hostname' line in the running configuration.

Deterministic Validation

Yes

Manual Review

NA

Configuration example:

```
hostname INTEL_CR_RT_INT_BLN_01
```

control_00002

Domain

Explanation: This command defines the domain name for the device, which is a required parameter for generating cryptographic keys.

Command:

ip domain name *<company_name>*

Variables:

<company_name>

Not compliance condition:

1. Name does not match the assigned name by the client.

Exceptions

In some cases it is not necessary to use a domain.

Severity

Low

Risk

Missing or incorrect domain names prevent the successful generation of RSA keys required for secure protocols like SSH.

Remediation Recommendation

Apply the correct domain using: *ip domain name <company_name>*.

Evidence

The 'ip domain name' command in the running configuration.

Deterministic Validation

Yes

Manual Review

NA

Configuration example:

ip domain name acme.com

control_00003

AAA:

Explanation: Configures the Authentication, Authorization, and Accounting framework to manage user access and activity logging on the device.

Command:

```
aaa new model
aaa authentication password-prompt LOCAL_PASS:
aaa authentication username-prompt LOCAL_USER:
aaa authentication login default group <Variables:_tacacs_group> local
aaa authentication enable default group <Variables:_tacacs_group> enable
aaa authorization config-commands
aaa authorization exec default group <Variables:_tacacs_group> local if-authenticated
aaa authorization commands 1 default group <Variables:_tacacs_group> if-authenticated
aaa authorization commands 15 default group <Variables:_tacacs_group> if-authenticated
aaa accounting exec default start-stop group <Variables:_tacacs_group>
aaa accounting commands 1 default start-stop group <Variables:_tacacs_group>
aaa accounting commands 15 default start-stop group <Variables:_tacacs_group>
```

Variables:

<Variables:_tacacs_group>

Not compliance condition:

1. One of the commands is missing
2. Variables: <Variables:_tacacs_group> should match for every AAA command.
3. aaa new-model is missing.

Exceptions

The device that is being audited indicates specifically that AAA is not needed.

Severity

High

Risk

Incomplete AAA configuration can lead to unauthorized access, lack of accountability for administrative actions, and inability to log user sessions.

Remediation Recommendation

Implement the full AAA suite (Authentication, Authorization, and Accounting) pointing to the authorized TACACS group.

Evidence

All 'aaa' commands in the running configuration.

Deterministic Validation

Yes

Manual Review

NA

Configuration example:

```
aaa authentication password-prompt LOCAL_PASS:
aaa authentication username-prompt LOCAL_USER:
aaa authentication login default group ACME_TACACS_SERVER_GROUP local
aaa authentication enable default group ACME_TACACS_SERVER_GROUP enable
aaa authorization config-commands
aaa authorization exec default group ACME_TACACS_SERVER_GROUP local
if-authenticated
aaa authorization commands 1 default group ACME_TACACS_SERVER_GROUP
if-authenticated
aaa authorization commands 15 default group ACME_TACACS_SERVER_GROUP
if-authenticated
aaa accounting exec default start-stop group ACME_TACACS_SERVER_GROUP
aaa accounting commands 1 default start-stop group ACME_TACACS_SERVER_GROUP
aaa accounting commands 15 default start-stop group ACME_TACACS_SERVER_GROUP
```

control_00004

TACACS:

Explanation: Establishes communication with external TACACS+ servers to centralize security and administrative access control.

Command:

```
aaa new-model
tacacs server <tacacs_server_name_1>
  key 7 <key_value>
  timeout <timeout_value>
tacacs server <tacacs_server_name_2>
  key 7 <key_value>
  timeout <timeout_value>
```

#Server group

```
aaa group server tacacs+ <tacacs_group_name>  
  server name TAC-SRV-01  
  server name TAC-SRV-02  
ip tacacs source-interface <source_interface>
```

Variables:

```
<tacacs_server_name_1>  
<tacacs_server_name_2>  
<key_value>  
<timeout_value>  
<tacacs_group_name>  
<source_interface>
```

Not compliance condition:

1. The commands must be executed with the assigned Variables.

Exceptions

In some cases there is no TACACS servers active in the enviroment. This condition should be indicated prior to device configuration.

Some old IOS version does not support this commands.

Severity

High

Risk

Failure to communicate with central security servers forces the use of local accounts, making user management difficult and less secure across the network.

Remediation Recommendation

Define the TACACS+ servers with the appropriate keys and timeouts as specified by the security policy.

Evidence

'tacacs server' definitions and keys in the running configuration.

Deterministic Validation

Yes

Manual Review

No

Configuration example:

```
aaa new-model
tacacs server ACME_TACACS_01
address ipv4 192.168.100.100
key 7 0123456789
timeout 10
tacacs server ACME_TACACS_02
address ipv4 192.138.100.102
key 7 0123456789
timeout 10

aaa group server tacacs+ ACME_TACACS_SERVER_GROUP
server name ACME_TACACS_01
server name ACME_TACACS_02
ip tacacs source-interface Loopback0
```

control_00005

Local and emergency users

Explanation: Defines local user accounts and privileged mode passwords to ensure device access in case of network failure or emergency.

Command:

```
username <user> privilege <privilege_level> secret <password>
```

Variables:

```
<user>
<privelege_level>
<password>
```

Command to force encryption 9:

Command:

```
username <user> privilege <privilege_level> algorithm-type scrypt secret <password>
```

Variables:

```
<user>
<privelege_level>
<password>
```

Command enable secret.

Command:

enable secret <secret_psswd>

Variables:

<secret_psswd>

//username admin privilege 15 secret 01234567889

Not compliance condition:

1. Username should be present
2. Enable secret should be present
3. The commands must be executed with the assigned Variables:s.

Exceptions

No specific exceptions identified for this control.

Severity

High

Risk

Lack of local emergency accounts can result in total loss of access during a network or TACACS outage. Weak password algorithms are susceptible to brute-force attacks.

Remediation Recommendation

Configure a local admin user and 'enable secret' using high-security hashing algorithms like scrypt.

Evidence

'username' and 'enable secret' lines in the running configuration.

Deterministic Validation

Yes

Manual Review

No

Configuration example:

username admin privilege 15 secret 0123456789

or

username admin privilege 15 algorithm-type scrypt secret 0123456789
enable secret 0123456789

control_00006

SSH:

Prerequisites before enabling SSH

hostname <HOSTNAME>

ip domain-name <DOMAIN.NAME>

RSA Key Generation

Commands:

crypto key zeroize rsa

crypto key generate rsa modulus 2048

ip ssh version <ssh_version>

ip ssh time-out <ssh_timeout>

ip ssh authentication-retries <ssh_auth_retries>

Variables:

<ssh_version>

<ssh_timeout>

ssh_auth_retries>

Not compliance condition:

1. Hostname is not configured.
2. IP domain-name is not configured.
3. RSA key generation (modulus 2048) is missing.

Exceptions

No specific exceptions identified for this control.

Severity

High

Risk

Insecure or missing RSA keys prevent encrypted management traffic, leaving administrative sessions vulnerable to eavesdropping.

Remediation Recommendation

Generate RSA keys with a minimum modulus of 2048 bits after setting the hostname and domain.

Evidence

Output of 'show ip ssh' or absence of zeroize commands.

Deterministic Validation

Yes

Manual Review

No

Configuration example:

```
crypto key zeroize rsa
crypto key generate rsa modulus 2048
ip ssh version 2
ip ssh time-out 60
ip ssh authentication-retries 3
```

control_00008

Telnet Blocking

Explanation: Restricts remote access to the SSH protocol only, blocking Telnet to prevent sending credentials in clear text.

Command:

```
line vty <vty_line_numbers>
transport input ssh
transport output ssh
```

Variables:

<vty_line_numbers>

Not compliance condition:

1. Telnet (port 23) is enabled for VTY lines.
2. 'transport input ssh' command is missing on VTY lines.

Exceptions

No specific exceptions identified for this control.

Severity

High

Risk

Allowing Telnet allows administrative credentials and data to be transmitted in plain text, which can be captured by attackers on the network.

Remediation Recommendation

Strictly limit transport input to SSH on all VTY lines.

Evidence

'transport input ssh' under 'line vty' in the running configuration.

Deterministic Validation

Yes

Manual Review

No

Configuration example:

```
line vty 0 15
access-class <VTY_ACL_NAME> in
exec-timeout 10 0
transport input ssh
transport output ssh
logging synchronous
session-timeout 10
exec prompt timestamp
history size 20
```

control_00009

NTP

Explanation: Configures time synchronization with NTP servers to ensure system logs have accurate timestamps.

Command:

```
ntp server <ntp_ip_address> prefer
ntp server <secondary_ntp_ip_address>
```

Variables:

```
<ntp_ip_address>
<secondary_ntp_ip_address>
```

Not compliance condition:

1. NTP server configuration is missing.
2. 'prefer' keyword is missing on the primary NTP server.

Exceptions

No specific exceptions identified for this control.

Severity

Medium

Risk

Drifting clocks lead to inaccurate log timestamps, making forensic analysis and event correlation during a security incident nearly impossible.

Remediation Recommendation

Configure at least two reliable NTP servers and use the 'prefer' keyword for the primary source.

Evidence

'ntp server' lines and 'show ntp associations' output.

Deterministic Validation

Yes

Manual Review

No

Configuration example:

```
ntp server 10.10.10.100 prefer
ntp server 20.20.20.100
```

control_00010

Syslog

Explanation: Enables sending event logs to an external server for system monitoring, auditing, and troubleshooting.

Commnads:

```
logging on
logging host <ip_syslog_server>
logging trap informational
logging source-interface <syslog_interface>
```

Variables:

<ip_syslog_server>

<syslog_interface>

Not compliance condition:

1. 'logging on' command is missing.
2. Logging host IP address is missing.
3. Logging trap level is not set to 'informational'.
4. 'logging source-interface' is not configured correctly.

Exceptions

No specific exceptions identified for this control.

Severity

Medium

Risk

Without centralized logging, local logs may be overwritten or cleared by an attacker, leaving no trace of unauthorized activity.

Remediation Recommendation

Enable global logging and point it to a secure, external syslog server with an informational trap level.

Evidence

'logging' commands in the running configuration.

Deterministic Validation

Yes

Manual Review

No

Configuration example:

logging on

logging host 30.30.30.100

logging trap informational

logging source-interface loopback 0

control_00011

SNMP

Explanation: Configures the SNMPv3 protocol with encryption and authentication for secure management and monitoring of network devices.

Command:

```
snmp-server group <group_name> v3 priv
snmp-server user <user_name><group_name> v3 auth sha <auth_password> priv aes 128
<priv_password>
snmp-server host <snmp_server_ip> version 3 priv <user_name>
snmp-server enable traps
```

Variables:

```
<group_name>
<user_name><group_name>
<auth_password>
<priv_password>
<snmp_server_ip>
<user_name>
```

Not compliance condition:

1. SNMPv3 group with 'priv' is not configured.
2. SNMPv3 user is not created with SHA/AES configuration.
3. SNMP trap host is missing.
4. 'snmp-server enable traps' command is missing.

Exceptions

No specific exceptions identified for this control.

Severity

High

Risk

SNMPv1/v2 transmit community strings in clear text. SNMPv3 without 'priv' lacks encryption, exposing monitoring data and control to interception.

Remediation Recommendation

Use SNMPv3 with authentication (SHA) and privacy (AES) exclusively.

Evidence

'snmp-server' configuration lines and 'show snmp user' output.

Deterministic Validation

Yes

Manual Review

No

Configuration example:

```
snmp-server group acme_snmp_grp01 v3 priv
snmp-server user acme_snmp_user acme_snmp_grp01 v3 auth sha 0123456789 priv aes
128 9876543210
snmp-server host 40.40.40.100 version 3 priv snmp_priv_psswd
snmp-server enable traps
```

control_00012

Banners

Explanation: Defines legal or informative messages displayed to users when attempting to access the device.

Command:

```
banner motd $ <message_of_the_day> $
```

Variables:

<message_of_the_day>

Not compliance condition:

1. Banner MOTD is not configured.
2. Banner message does not match corporate policy.

Exceptions

No specific exceptions identified for this control.

Severity

Medium

Risk

The absence of legal banners can complicate the legal prosecution of unauthorized users and fails to warn attackers of monitoring.

Remediation Recommendation

Configure a 'banner motd' containing approved legal language regarding authorized access and monitoring.

Evidence

'banner motd' section in the running configuration.

Deterministic Validation

No

Manual Review

Yes

Configuration example:

```
banner motd $ ++This is the message of the day++ $
```

control_00013

Passwords

Explanation: Applies global password security policies, including minimum length and encryption of keys stored in the configuration.

Command:

```
security passwords min-length <minimum_length_number>  
service password-encryption
```

Variables:

<minimum_length_number>

Not compliance condition:

1. 'security passwords min-length' is not configured or below the minimum length requirement.
2. 'service password-encryption' is missing.

Exceptions

No specific exceptions identified for this control.

Severity

High

Risk

Short or unencrypted passwords are easily cracked via dictionary attacks or discovered within the configuration file if the device is compromised.

Remediation Recommendation

Set a global minimum password length (at least 10) and enable the password encryption service.

Evidence

'security passwords min-length' and 'service password-encryption' commands.

Deterministic Validation

Yes

Manual Review

No

Configuration example:

```
security passwords min-length 10
service password-encryption
```

control_00014

VTY Lines

Explanation: Configures access and security parameters for console and virtual terminal lines, controlling direct and remote administrative access.

Command:

```
! Console line configuration
line console 0
password <console_password>
login local
exec-timeout <minutes><seconds>
logging synchronous
exit
```

Command:

```
! VTY lines configuration
line vty <start_line_number><end_line_number>
password <vtty_password>
login local
```

exec-timeout <minutes><seconds>
transport input <allowed_protocols>
logging synchronous
exit

Variables:

<console_password>
console timeout: <minutes><seconds>
<start_line_number><end_line_number>
<vty_password>
vty timeout: <minutes><seconds>
<allowed_protocols>

Not compliance condition:

1. Console or VTY passwords are missing.
2. 'login local' is missing.
3. 'exec-timeout' is missing.
4. 'transport input' is not restricted to secure protocols.

Exceptions

No specific exceptions identified for this control.

Severity

High

Risk

Open VTY/Console sessions without timeouts can be hijacked. Insecure protocol support allows for credential theft.

Remediation Recommendation

Apply 'exec-timeout', 'login local', and restrict transport protocols for all access lines.

Evidence

Configuration blocks for 'line console 0' and 'line vty'.

Deterministic Validation

Yes

Manual Review

No

Configuration example:

```
line vty 0 15
```

```
access-class <VTY_ACL_NAME> in
exec-timeout 10 0
transport input ssh
transport output ssh
logging synchronous
session-timeout 10
exec prompt timestamp
history size 20
```

control_00015

Basic Security

Explanation: Establishes fundamental protection measures, such as the enable password and the creation of a local administrator with full privileges.

Command:

! Secure the privileged EXEC mode
enable secret <enable_password>

Command:

! Create a local administrator account with full privileges
username <user_name> privilege 15 secret <user_password>

Variables:

<enable_password>
<user_name>
<user_password>

Not compliance condition:

1. Enable secrets are missing.
2. Local administrator with privilege 15 is not created.

Exceptions

No specific exceptions identified for this control.

Severity

High

Risk

Failure to secure the privileged mode allows any user with standard access to potentially take full control of the network device.

Remediation Recommendation

Ensure an 'enable secret' and a privilege 15 local administrator account are present and secured.

Evidence

'enable secret' and 'username ... privilege 15' in configuration.

Deterministic Validation

Yes

Manual Review

No

Configuration example:

```
enable secret 0123456789
```

control_00016

Mandatory Commands

Severity

High

Risk

Omitting baseline security commands leaves the device vulnerable to common automated attacks and misconfigurations.

Remediation Recommendation

Review and apply all commands marked as mandatory in the security policy.

Evidence

Presence of specific mandatory command strings in running config.

Deterministic Validation

Yes

Manual Review

No

Configuration example:

NA

control_00017

Recommended Commands:

Explanation: Implements suggested security hardening commands, such as local brute-force protection and robust hashing algorithms.

Emergency local account (break-glass)

Command:

```
username <LOCAL_ADMIN> privilege 15 algorithm-type scrypt secret  
<STRONG_PASSWORD>
```

Variables:

```
<LOCAL_ADMIN>  
<STRONG_PASSWORD>
```

Failed attempts blocking (local brute-force protection)

Command:

```
login block-for <blocked_time> attempts <attempts_number> within <attempts_time>  
login delay <login_delay>  
login on-failure log  
login on-success log
```

Variables:s:

```
<blocked_time>  
<attempts_number>  
<attempts_time>  
<login_delay>
```

Minimum password length

Command:

```
security passwords min-length <password_length>
```

Variables:

```
<password_length>
```

Configure the default algorithm globally to apply to all future creation:

Command:

```
username <admin_user> algorithm-type scrypt secret <user_password>
```

Variables:

<admin_user>

<user_password>

Not compliance condition:

1. 'login block-for' or 'login delay' settings are missing.
2. 'security passwords min-length' is below 10.
3. Scrypt algorithm is not configured.

Exceptions

No specific exceptions identified for this control.

Severity

Medium

Risk

Without brute-force protection, attackers can use automated scripts to guess local passwords without being blocked or logged.

Remediation Recommendation

Implement 'login block-for' and 'login delay' to mitigate automated login attempts.

Evidence

'login block-for' and 'login delay' commands in configuration.

Deterministic Validation

Yes

Manual Review

No

Configuration example:

NA

control_00018

Prohibited Commands

Severity

High

Risk

Executing prohibited commands (e.g., 'no logging', 'ip http server') can create significant security holes or hide malicious activity.

Remediation Recommendation

Disable or remove any prohibited services or commands as listed in the corporate blacklist.

Evidence

Absence of prohibited command strings in the running configuration.

Deterministic Validation

Yes

Manual Review

No

Configuration example:

NA